SECURITY NINJA GERMANY



YOU'VE GOT DETECTION RULES

BUT WILL THEY SPOT A REAL ATTACKER?

Jay Kerai • Effie Antoniadi



Session

Jay Kerai
Cybersecurity Automation Architect



Session

Effie Antoniadi
SOC Engineer
Cegeka

Session

#SecNinjas

About Jay

Focus

Microsoft Defender XDR

Azure

Sentinel

Entra ID

Certifications

Too many to list



Hobbies

Travelling!

Going to Metal Concerts

Being a Microsoft Nerd

Blog

Linkedin.com/in/jay-kerai-cyber

Contact

https://aka.ms/M365EMSDiscord

KQL Search

Microsoft Most Valuable Professional

About

Focus

Microsoft Defender XDR
Microsoft Intune
Entra ID

From

Greece

Blog

Linkedin.com/in/eantoniadi



Certification

Microsoft Certified Trainer
MD-102, MS-102, SC-401, SC-300

Hobbies

Pets, tech, Legos

Contact

https://aka.ms/M365EMS Discord

KQL Search

Thank you to our Sponsors!

Host Partner

Microsoft

Gold

glueck kanja

water IT Security & Defense

robopack

PROACT

Silver

WORKSIMPLE EINFACH ARBEITEN

semperis

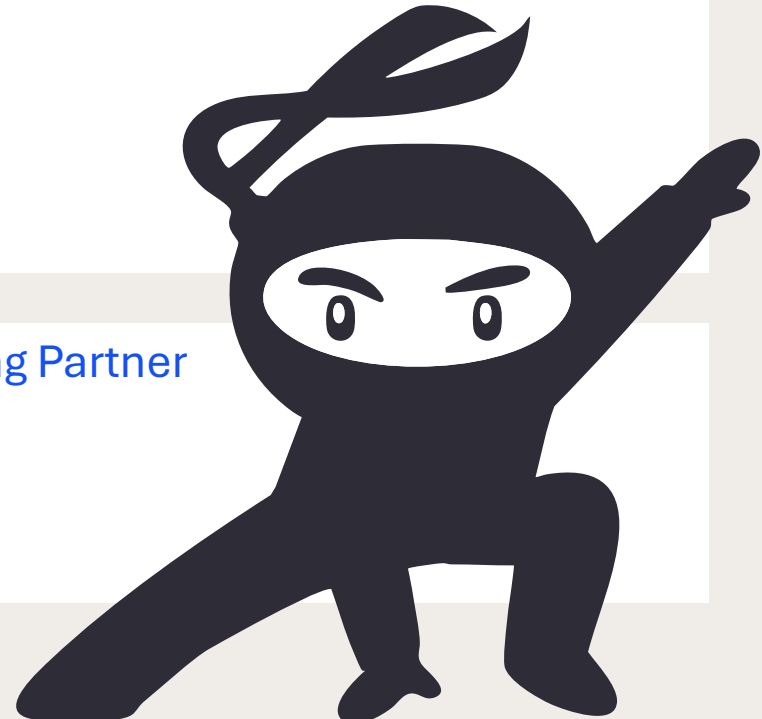
Bronze

ugurlabs

IC CONSULT

Snacks & Networking Partner

SCE



Abstract



Are your detection rules actually capable of spotting a real attacker, or are you just assuming they work?

In this session, we'll explore common detection engineering pitfalls and demonstrate how **Atomic Red Team** and **MITRE ATT&CK** can help validate security controls.

Through a live demonstration, we'll simulate attacker techniques, investigate telemetry in **Microsoft Defender XDR**, and use **KQL Advanced Hunting** to identify detection gaps.

The goal: Move beyond simply deploying detection rules and start continuously testing, validating, and improving your security posture.

Microsoft
glueckkanja
water IT Security & Defense
robopack
PROACT
WORKSIMPLE EINFACH ARBEITEN
semperis
ugurlabs
iC CONSULT

The uncomfortable starting point

29.2%

of deployed detection rules were reported broken

Spectrum Security, Detection Debt 2026

One attack. Four questions.

01

Did it run?

02

Was it blocked?

03

Was it visible?

04

Did our rule fire?

MITRE ATT&CK / Tactics vs techniques

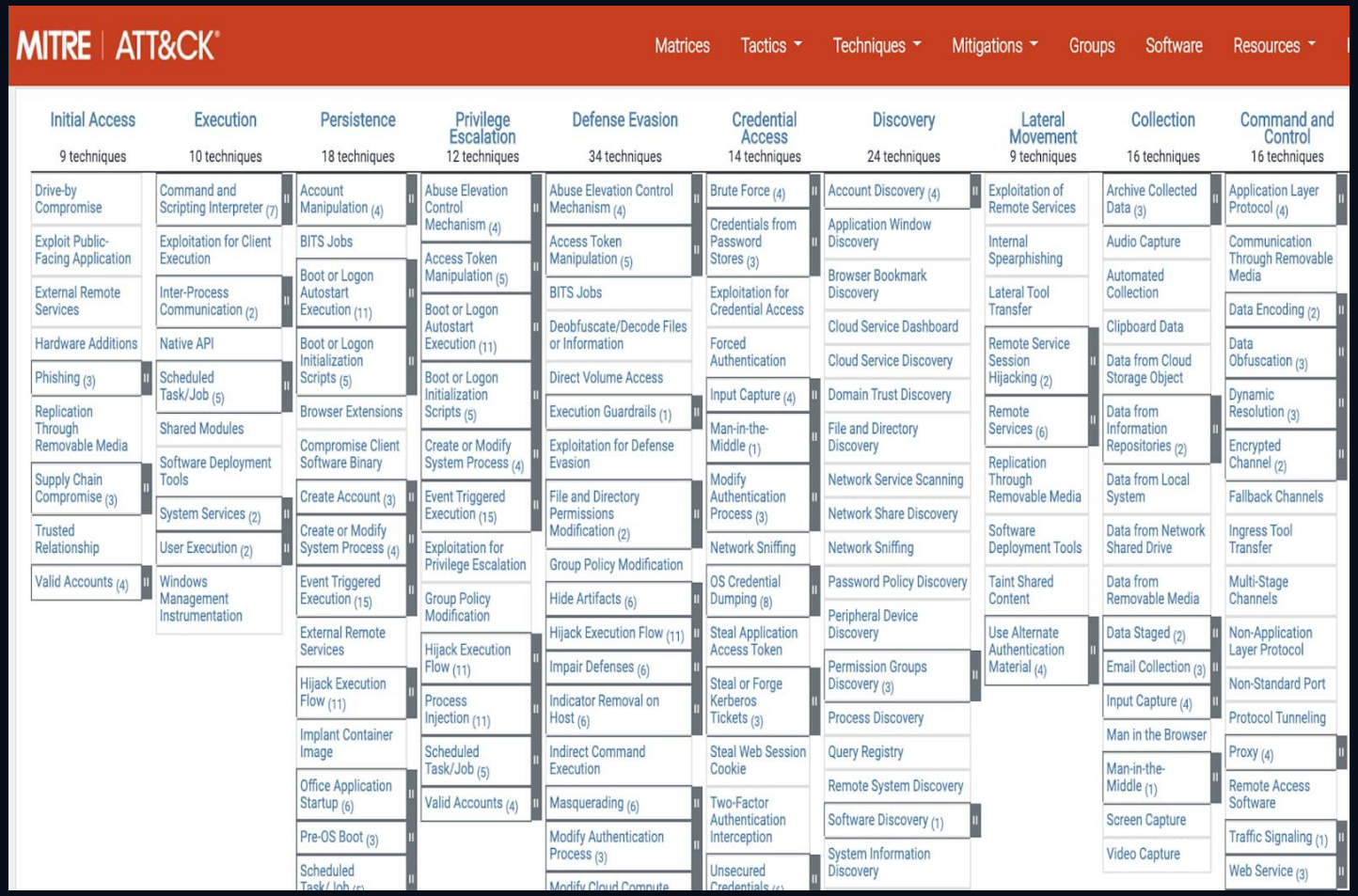
SECURITY NINJA

TACTIC - WHY

Tactics describe why an attacker performs a certain action e.g., Credential Access

TECHNIQUE - HOW

The behavior used to achieve that objective.



Why detection rules fail

Overly scoped strings

Detections rely on specific filenames, paths, or command-line fragments. What if the binary runs from a different path or with a different name?

Too much tuning

Rules get over-tuned to reduce alert fatigue, then fail to fire in a real scenario.

AI hallucinated event types

AI can suggest event types that do not exist — and KQL may not error out on this.

Product reliance

‘Won’t MDE P2 pick this up anyway?’ Native coverage is often assumed without being validated.

Native vs custom detection

If the product already detects it natively, when is writing a custom detection still worth it?

Tamper & control dependency

Can the blocking product be tampered with — and is that monitored? Do you still get a detection if the blocking control is disabled?

A rule that only knows one filename

Attacker executes a technique

MATCH EXACT STRING

```
C:\Temp\tool.exe
```

SAME BEHAVIOUR

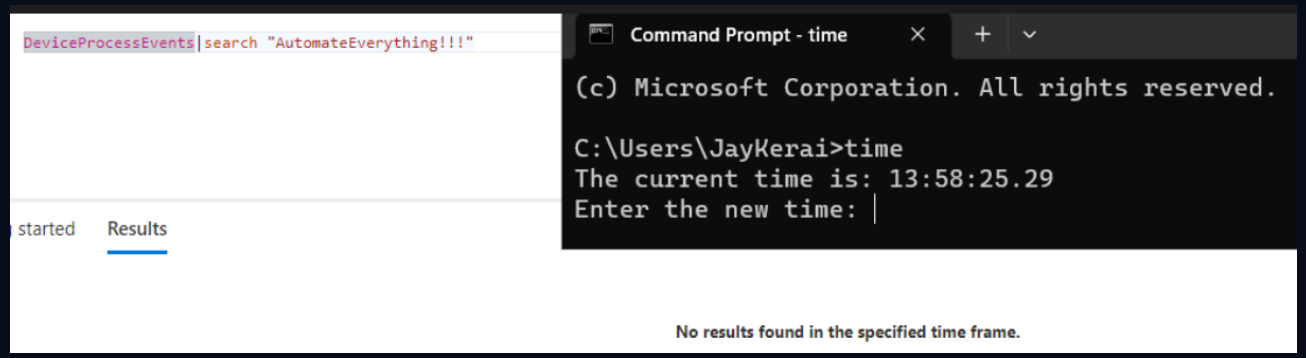
```
C:\Users\Public\a.exe
```

Does your rule detect the technique - or just the string?

Example


```
Y:\>echo AutomateEverything!!!
AutomateEverything!!!

Y:\>time
The current time is: 13:35:14.87
```



Process Command lines not guaranteed

Can you still detect the behaviour thereafter?

Usually at mercy of the product, in this case MDE!

Blocking is not the same as detection

PREVENT

Endpoint protection stops execution.

Great outcome, but what happens when the control changes?

DETECT

Signals create visibility that analysts can investigate.

Something blocked should still provide telemetry to SOC.

Validate the signal under real test conditions.

Control validation ≠ detection validation

Atomic Red Team, in 30 seconds

SECURITY NINJA

SMALL TESTS.
REAL TECHNIQUES.

An open-source library of ATT&CK-aligned tests. Not a substitute for a full red team engagement.

Why Atomic Red Team?

SECURITY NINJA

Accessible

Free and open source (MIT license); simple, focused exercises.

ATT&CK-aligned

Small tests based on TTPs used by real adversaries.

Repeatable & adaptable

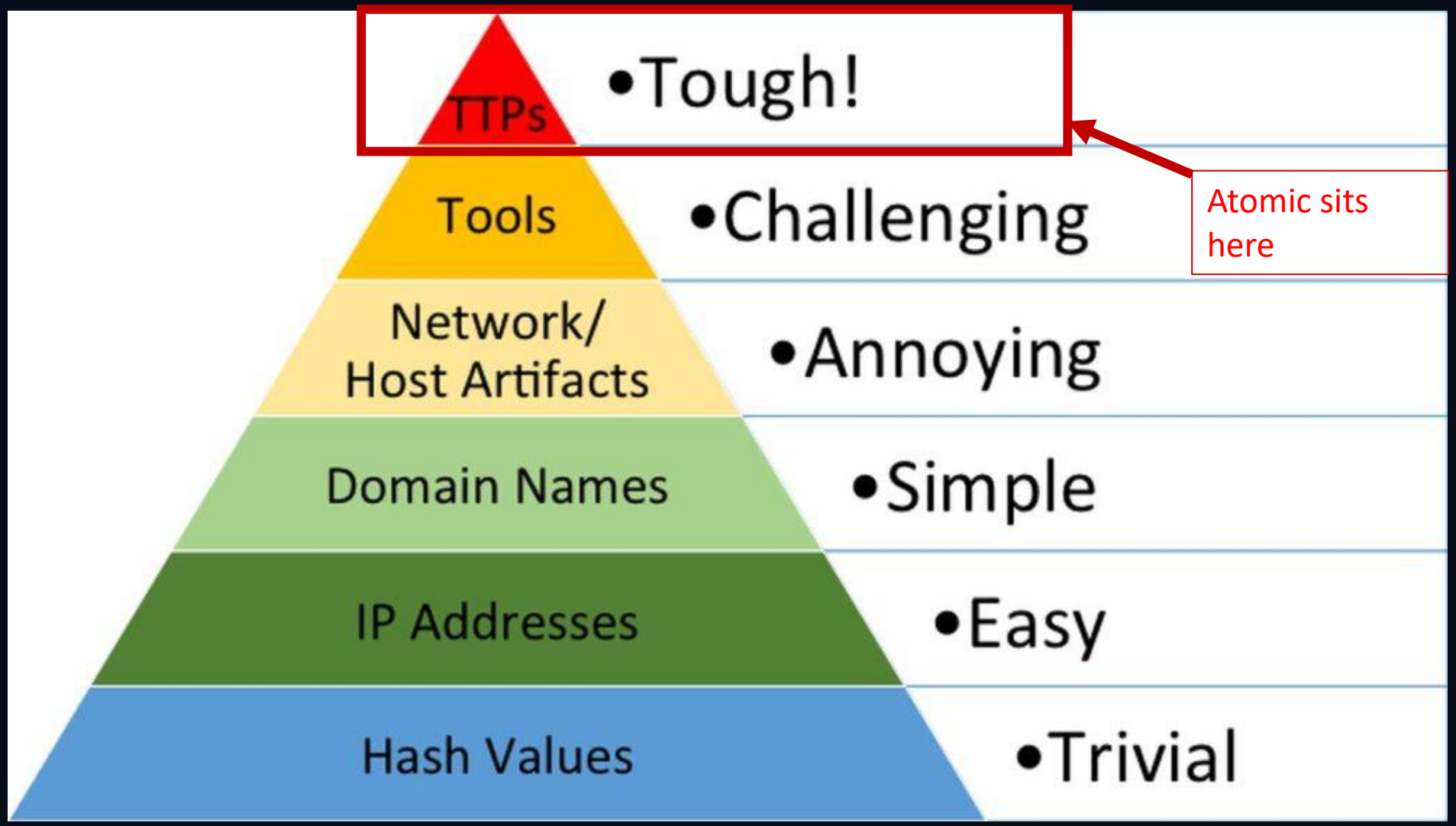
Use tests with different runners or adjust input arguments.

Not a full red team

A cost-effective complement to purple teaming, not a complete adversary simulation.

Atomic tests are test definitions-not inherently malware. Individual test payloads still require review and authorization.

Pyramid of Pain



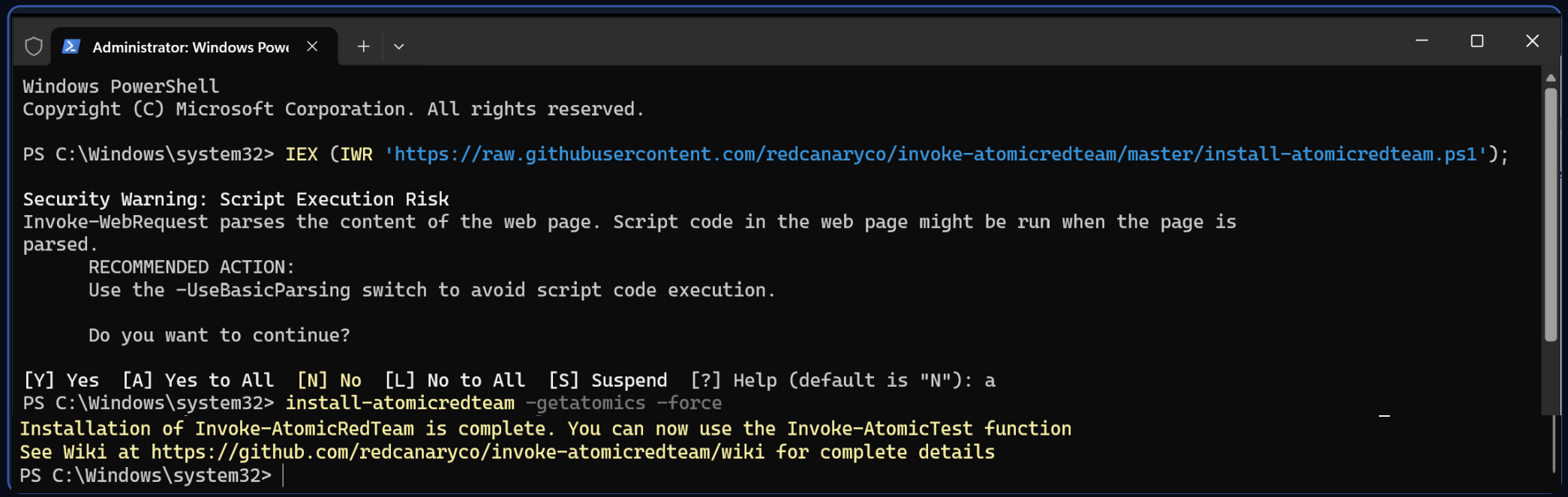
Before you press Enter

- Use a dedicated, authorized lab host / VM (admin rights ideal)
- Onboard it to Defender; verify expected telemetry
- Account in Active Directory/Entra Ideal
- Use tightly scoped exceptions only when essential
- Plan cleanup and restore all temporary changes

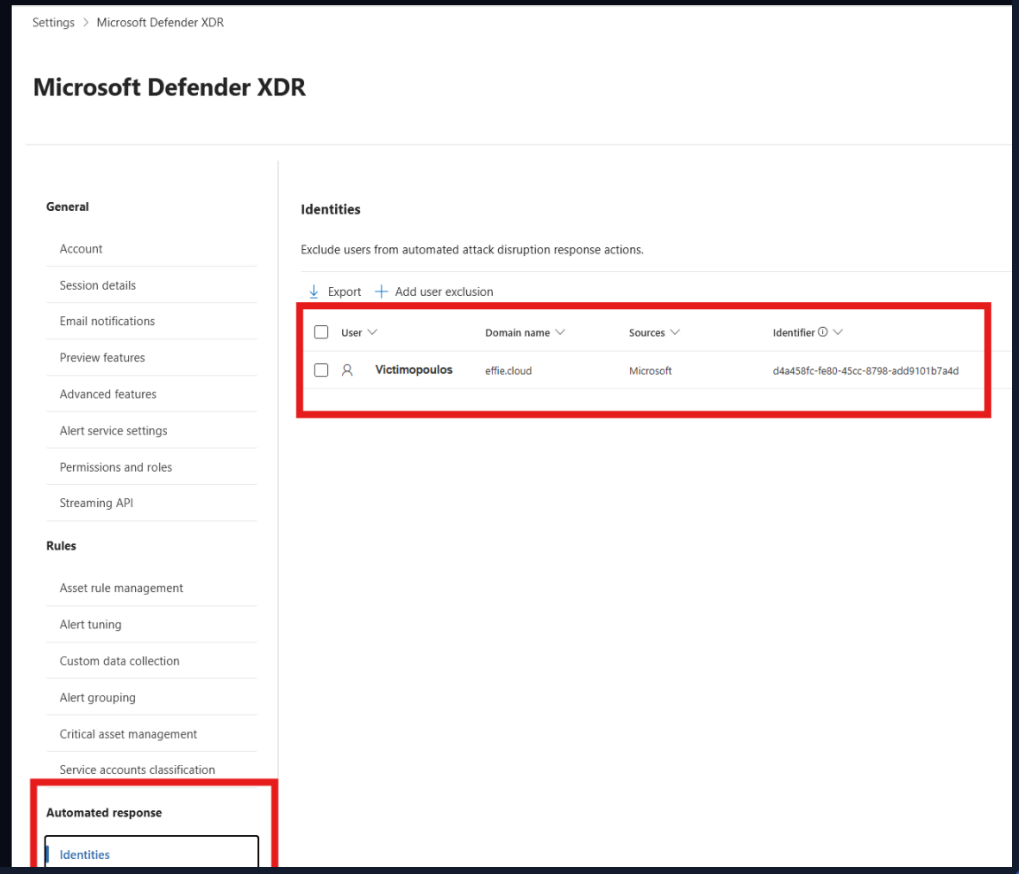
The validation loop



LAB SETUP / Atomic installation



LAB SETUP / Attack Disruption (User)



WHY EXCLUDE THE LAB IDENTITY?

Attack Disruption can automatically contain a compromised identity and interrupt an authorized simulation.

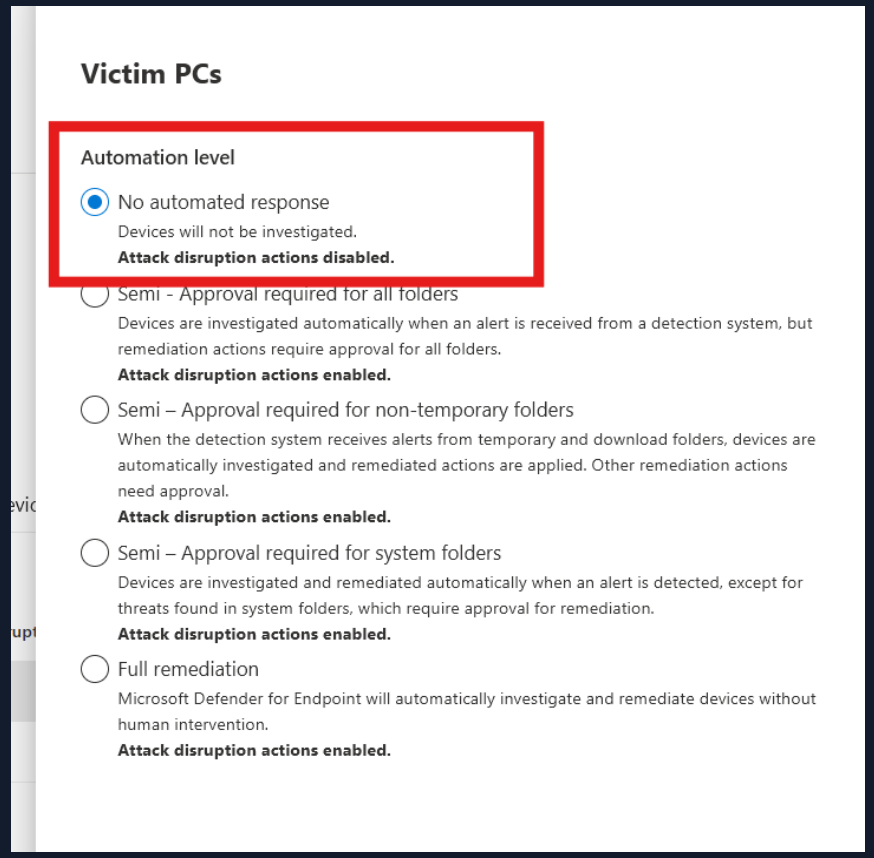
DEFENDER XDR PATH

security.microsoft.com → Settings → Microsoft Defender XDR → Automated response → Identities

IDENTITY ≠ DEVICE EXCLUSION

Identity exceptions apply to selected users. Device exceptions are configured separately under Automated response → Devices and may require a device group.

LAB SETUP / Attack Disruption (Devices)



WHY EXCLUDE THE LAB DEVICE?

Attack Disruption can automatically contain a compromised device and interrupt an authorized simulation.

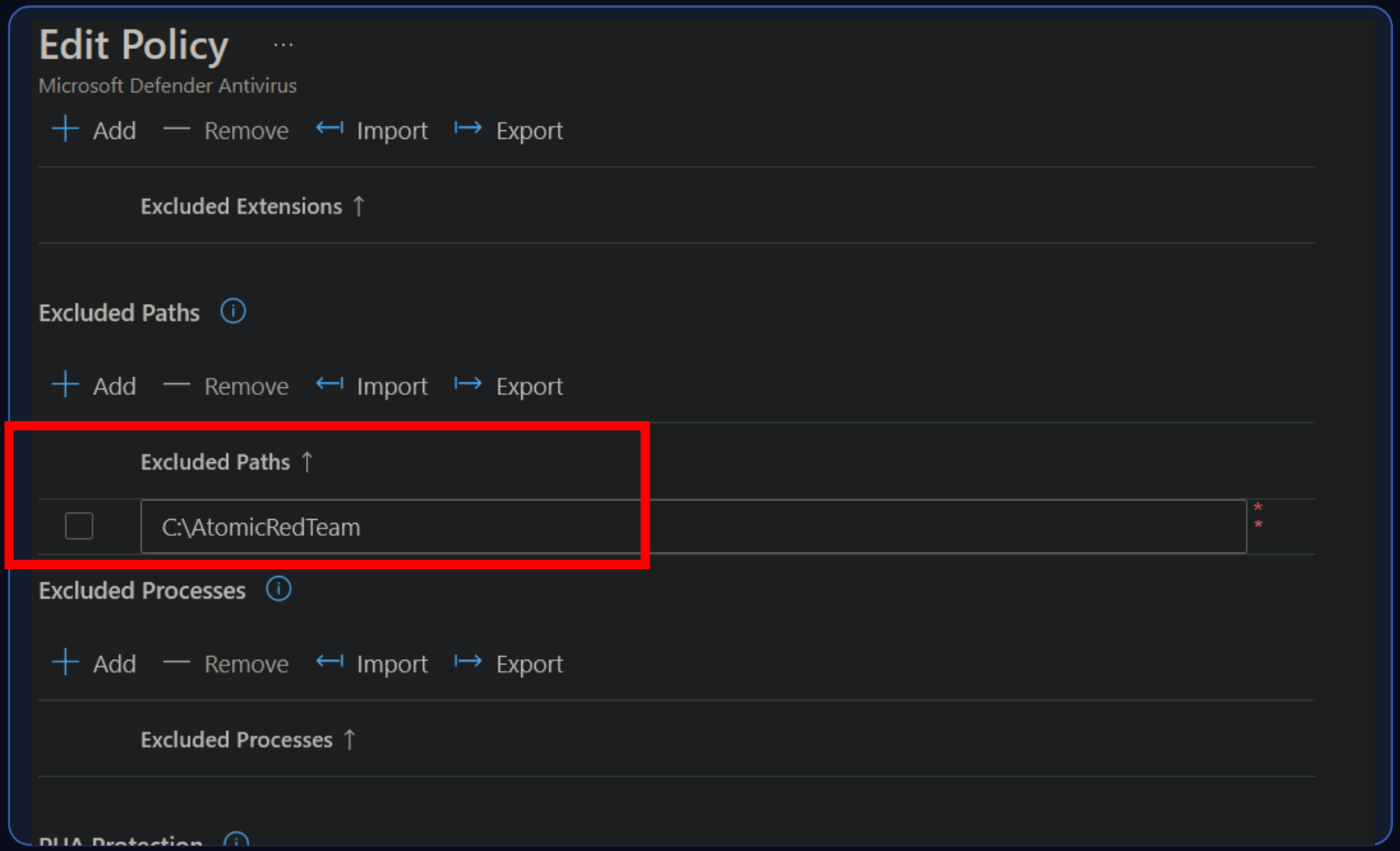
DEFENDER XDR PATH

security.microsoft.com → Settings → Microsoft Defender XDR → Automated response → Devices

Device Group Required!

If using unified RBAC ensure SOC has access to the device group

LAB SETUP / Antivirus policy



What exactly is an atomic test?

ATT&CK TECHNIQUE

Mapped adversary behaviour

Example: T1059.001 - PowerShell

TEST SPECIFICATION

YAML definition with commands, inputs, prerequisites and cleanup.

Execution framework → checks prerequisites → runs test → logs execution → cleanup

Atomic Red Team vs execution framework

SECURITY NINJA



Value is here – the EF can be dropped in for another one

TEST LIBRARY

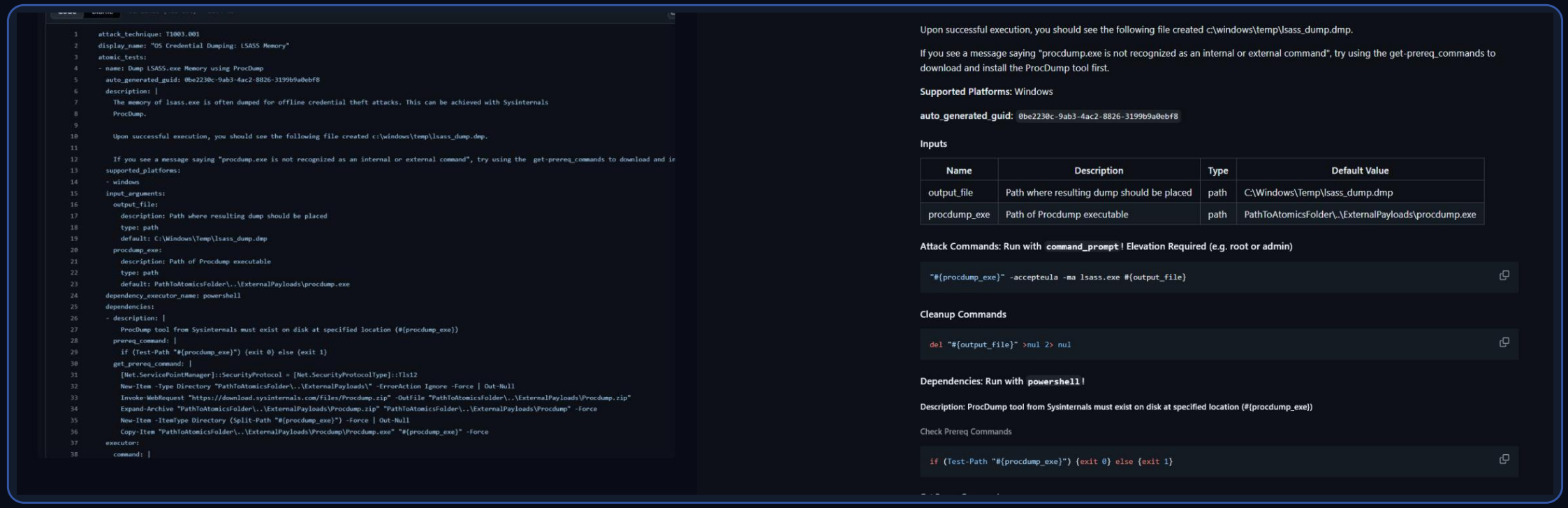
redcanaryco/atomic-red-team: YAML definitions, command examples, prerequisites, cleanup.

EXECUTION FRAMEWORK

redcanaryco/invoke-atomicredteam: tooling that reads and runs selected tests.

The test library can be reused with a different execution framework.

DEMO / Choose the atomic test



```yaml
attack_technique: T1003.001
display_name: "OS Credential Dumping: LSASS Memory"
atomic_tests:
- name: Dump LSASS.exe Memory using ProcDump
  auto_generated_guid: 0be2230c-9ab3-4ac2-8826-3199b9a0ebf8
  description: |
    The memory of lsass.exe is often dumped for offline credential theft attacks. This can be achieved with Sysinternals
    ProcDump.

    Upon successful execution, you should see the following file created c:\windows\temp\lsass_dump.dmp.

    If you see a message saying "procdump.exe is not recognized as an internal or external command", try using the  get-prereq_commands to download and in
  supported_platforms:
  - windows
  input_arguments:
    output_file:
      description: Path where resulting dump should be placed
      type: path
      default: C:\Windows\Temp\lsass_dump.dmp
    procdump_exe:
      description: Path of Procdump executable
      type: path
      default: PathToAtomicsFolder\..\ExternalPayloads\procdump.exe
  dependency_executor_name: powershell
  dependencies:
  - description: |
      ProcDump tool from Sysinternals must exist on disk at specified location (#{procdump_exe})
    prereq_command: |
      if (Test-Path "#{procdump_exe}") {exit 0} else {exit 1}
    get_prereq_command: |
      [Net.ServicePointManager]::SecurityProtocol = [Net.SecurityProtocolType]::Tls12
      New-Item -Type Directory "PathToAtomicsFolder\..\ExternalPayloads\" -ErrorAction Ignore -Force | Out-Null
      Invoke-WebRequest "https://download.sysinternals.com/files/Procdump.zip" -OutFile "PathToAtomicsFolder\..\ExternalPayloads\Procdump.zip"
      Expand-Archive "PathToAtomicsFolder\..\ExternalPayloads\Procdump.zip" "PathToAtomicsFolder\..\ExternalPayloads\Procdump" -Force
      New-Item -ItemType Directory (Split-Path "#{procdump_exe}") -Force | Out-Null
      Copy-Item "PathToAtomicsFolder\..\ExternalPayloads\Procdump\Procdump.exe" "#{procdump_exe}" -Force
  executor:
    command: |
```

Upon successful execution, you should see the following file created c:\windows\temp\lsass_dump.dmp.

If you see a message saying "procdump.exe is not recognized as an internal or external command", try using the get-prereq_commands to download and install the ProcDump tool first.

Supported Platforms: Windows

auto_generated_guid: `0be2230c-9ab3-4ac2-8826-3199b9a0ebf8`

Inputs

Name	Description	Type	Default Value
output_file	Path where resulting dump should be placed	path	C:\Windows\Temp\lsass_dump.dmp
procdump_exe	Path of Procdump executable	path	PathToAtomicsFolder\..\ExternalPayloads\procdump.exe

Attack Commands: Run with `command_prompt`! Elevation Required (e.g. root or admin)

```
"#{procdump_exe}" -accepteula -ma lsass.exe #{output_file}
```

Cleanup Commands

```
del "#{output_file}" >nul 2> nul
```

Dependencies: Run with `powershell`!

Description: ProcDump tool from Sysinternals must exist on disk at specified location (#{procdump_exe})

Check Prereq Commands

```
if (Test-Path "#{procdump_exe}") {exit 0} else {exit 1}
```

Original atomic YAML and test documentation

Invoke-AtomicTest / Key switches

SECURITY NINJA

-ShowDetails / -ShowDetailsBrief

Inspect test definition before execution

-TestNumbers / -TestNames

Select exactly which test to run

-CheckPrereqs / -GetPrereqs

Check or install prerequisites, when authorized

-Cleanup

Run test-defined cleanup commands

-PromptForInputArgs

Provide alternate input values

-Session / -PathToAtomicsFolder

Remote session or alternate test library path

Demo Part 1 / Execute

Technique: PowerShell (ATT&CK T1059.001)

```
Invoke-AtomicTest T1059.001 -ShowDetailsBrief

Invoke-AtomicTest T1059.001 -CheckPrereqs

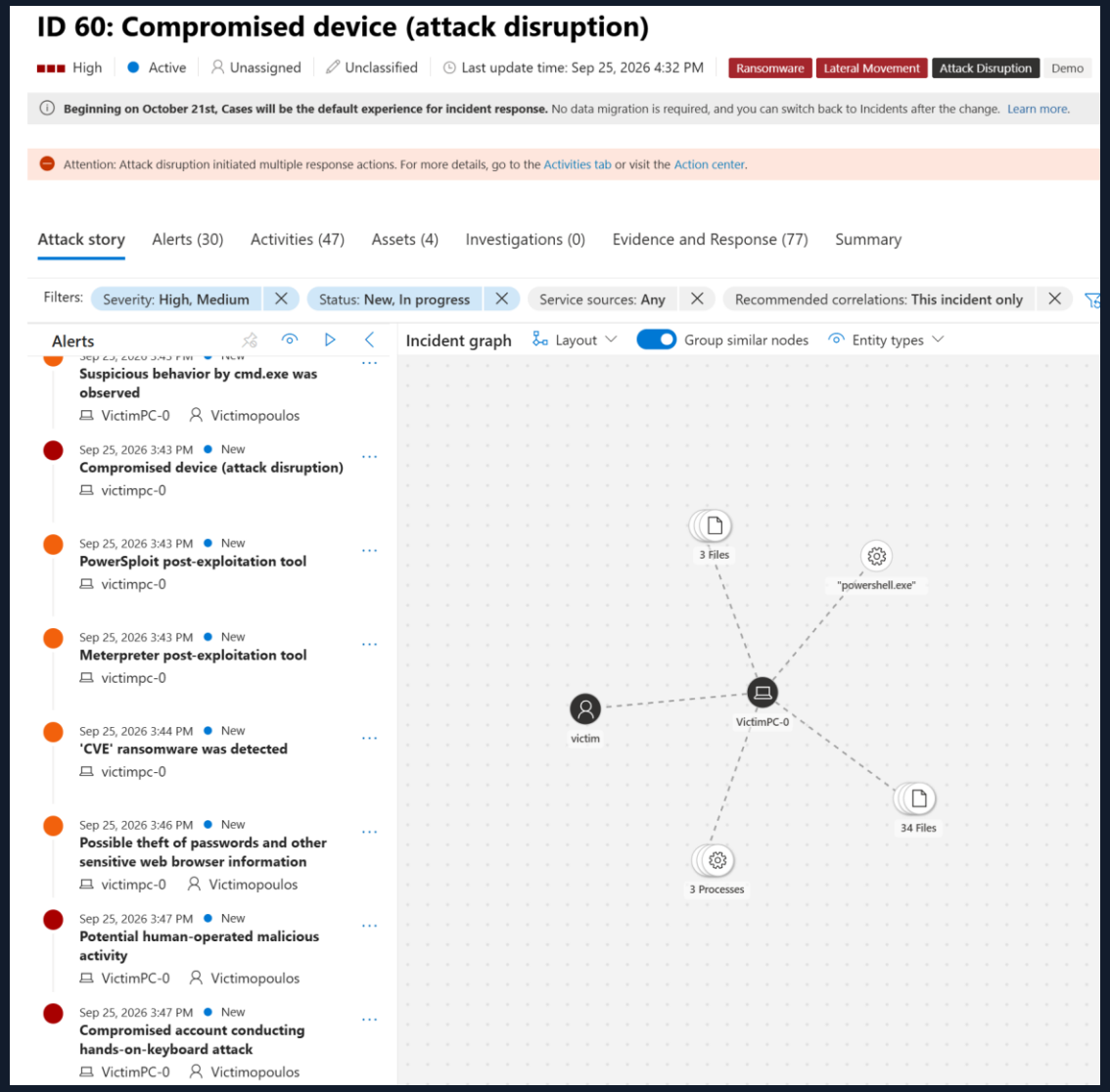
Invoke-AtomicTest T1059.001 -Cleanup
```

Demo Part 1 / Execute

Technique: PowerShell (ATT&CK T1059.001)

Atomic Test #1: Mimikatz
Atomic Test #2: Run BloodHound from local disk
Atomic Test #3: Run Bloodhound from Memory using Download Cradle
Atomic Test #4: Mimikatz - Cradlecraft PsSendKeys
Atomic Test #5: Invoke-AppPathBypass
Atomic Test #6: Powershell MsXml COM object - with prompt
Atomic Test #7: Powershell XML requests
Atomic Test #8: Powershell invoke mshta.exe download
Atomic Test #9: Powershell Invoke-DownloadCradle
Atomic Test #10: PowerShell Fileless Script Execution
Atomic Test #11: NTFS Alternate Data Stream Access
Atomic Test #12: PowerShell Session Creation and Use
Atomic Test #13: ATHPowerShellCommandLineParameter -Command parameter variations
Atomic Test #14: ATHPowerShellCommandLineParameter -Command parameter variations with encoded arguments
Atomic Test #15: ATHPowerShellCommandLineParameter -EncodedCommand parameter variations
Atomic Test #16: ATHPowerShellCommandLineParameter -EncodedCommand parameter variations with encoded arguments
Atomic Test #17: PowerShell Command Execution
Atomic Test #18: PowerShell Invoke Known Malicious Cmdlets
Atomic Test #19: PowerUp Invoke-AllChecks
Atomic Test #20: Abuse Nslookup with DNS Records
Atomic Test #21: SOAPHound - Dump BloodHound Data
Atomic Test #22: SOAPHound - Build Cache

DEMO Part 1 / Defender detection



Demo part 2 / Hunt the telemetry

Defender XDR → Advanced Hunting

```
let labDevice = "REPLACE-WITH-LAB-DEVICE";
DeviceProcessEvents
| where Timestamp > ago(1h)
| where DeviceName =~ labDevice
| where FileName in~ ("powershell.exe", "pwsh.exe")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine
| order by Timestamp desc
```

DEMO Part 2 / What actually executed?

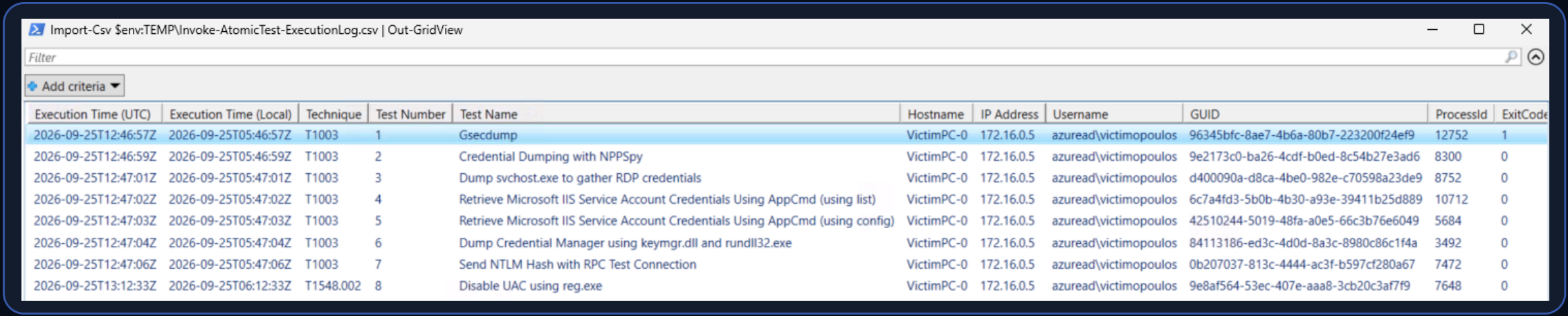
SECURITY NINJA

EXECUTED ≠ DETECTED

The framework can record the test run without proving an attack outcome or SOC alert.

VIEW THE CSV

Import-Csv $env:TEMP\Invoke-AtomicTest-ExecutionLog.csv | Out-GridView



Execution Time (UTC)	Execution Time (Local)	Technique	Test Number	Test Name	Hostname	IP Address	Username	GUID	ProcessId	ExitCode
2026-09-25T12:46:57Z	2026-09-25T05:46:57Z	T1003	1	Gsecdump	VictimPC-0	172.16.0.5	azuread\victimopoulos	96345bfc-8ae7-4b6a-80b7-223200f24ef9	12752	1
2026-09-25T12:46:59Z	2026-09-25T05:46:59Z	T1003	2	Credential Dumping with NPPSpy	VictimPC-0	172.16.0.5	azuread\victimopoulos	9e2173c0-ba26-4cdf-b0ed-8c54b27e3ad6	8300	0
2026-09-25T12:47:01Z	2026-09-25T05:47:01Z	T1003	3	Dump svchost.exe to gather RDP credentials	VictimPC-0	172.16.0.5	azuread\victimopoulos	d400090a-d8ca-4be0-982e-c70598a23de9	8752	0
2026-09-25T12:47:02Z	2026-09-25T05:47:02Z	T1003	4	Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using list)	VictimPC-0	172.16.0.5	azuread\victimopoulos	6c7a4fd3-5b0b-4b30-a93e-39411b25d889	10712	0
2026-09-25T12:47:03Z	2026-09-25T05:47:03Z	T1003	5	Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using config)	VictimPC-0	172.16.0.5	azuread\victimopoulos	42510244-5019-48fa-a0e5-66c3b76e6049	5684	0
2026-09-25T12:47:04Z	2026-09-25T05:47:04Z	T1003	6	Dump Credential Manager using keymgr.dll and rundll32.exe	VictimPC-0	172.16.0.5	azuread\victimopoulos	84113186-ed3c-4d0d-8a3c-8980c86c1f4a	3492	0
2026-09-25T12:47:06Z	2026-09-25T05:47:06Z	T1003	7	Send NTLM Hash with RPC Test Connection	VictimPC-0	172.16.0.5	azuread\victimopoulos	0b207037-813c-4444-ac3f-b597cf280a67	7472	0
2026-09-25T13:12:33Z	2026-09-25T06:12:33Z	T1548.002	8	Disable UAC using reg.exe	VictimPC-0	172.16.0.5	azuread\victimopoulos	9e8af564-53ec-407e-aaa8-3cb20c3af7f9	7648	0

https://github.com/redcanaryco/invoke-atomicredteam/wiki/Execution-Logging

The attack ran. Now what?

PREVENTED	Control blocked the technique
ALERT FIRED	Validate fidelity, response and triage flow
VISIBLE, NO ALERT	Telemetry exists; detection logic may need work
NO EXPECTED TELEMETRY	Review sensor, event source and prerequisites

Don’t just ask: Did an alert fire?

- Did the test execute as intended?
- What telemetry did Defender capture?
- Did our detection logic match that telemetry?
- Was there a product alert or incident?
- Did the SOC respond as expected?

A measurable result beats a green checkbox

EXPECTED

Technique, events and target control documented before execution.

OBSERVED

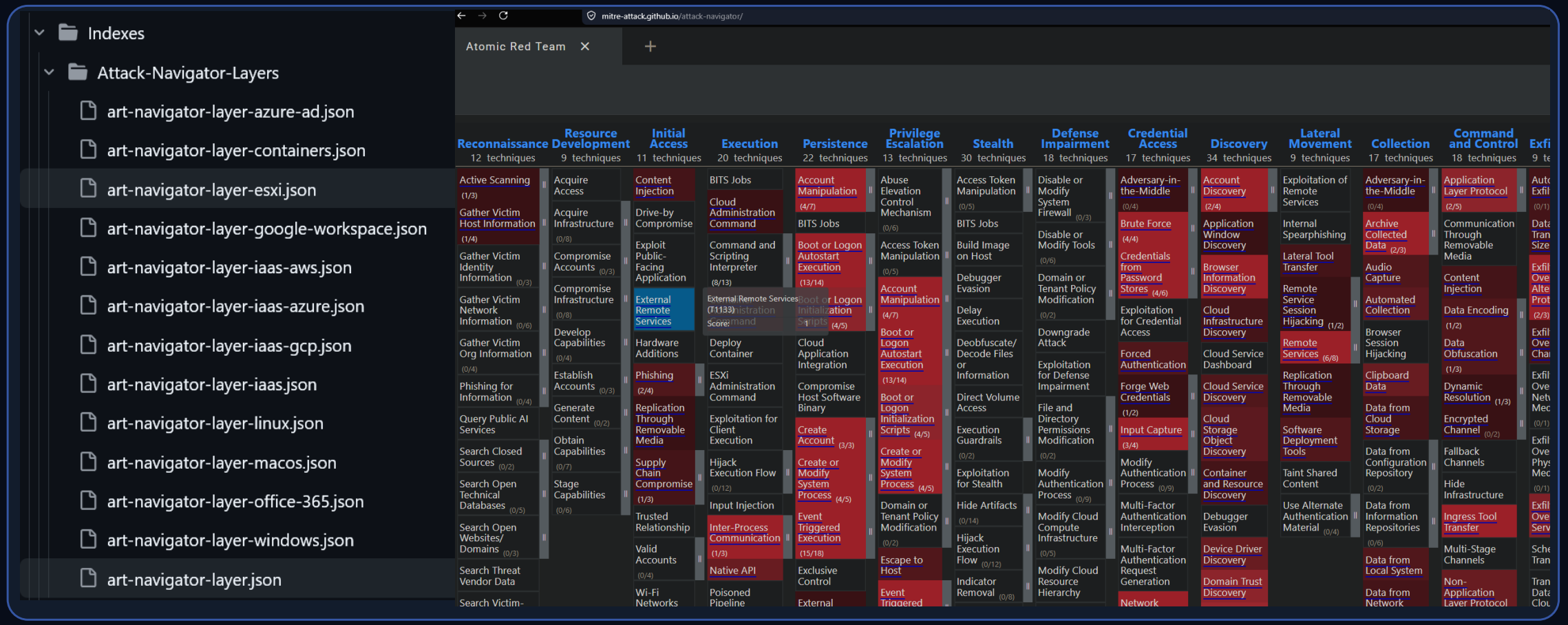
Atomic run status, captured telemetry, alerts and analyst actions.

NEXT ACTION

Tune detection, fix coverage, refine scope, or accept risk.

Keep evidence. Change something. Retest the same technique.

Limitations / Incomplete coverage



What should you do next week?

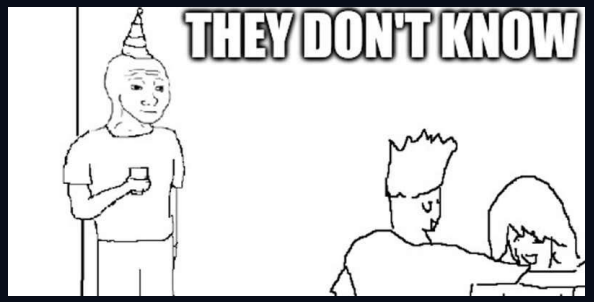
- Pick one high-priority ATT&CK technique
- Run a controlled atomic in your test environment
- Check actual endpoint telemetry and alerts
- Tune your control or detection, then rerun
- Document evidence and operationalize the test



DETECTION ≠ ASSUMPTION

IF YOU HAVEN'T TESTED IT, YOU DON'T KNOW.

Validate prevention. Validate detection. Validate response.



Conclusion

SIMULATE REGULARLY

Run breach-and-attack simulations with your security team - not just as a one-off exercise.

VALIDATE DETECTIONS AND CONTROLS

Check both whether an action was blocked and whether your team received usable detection evidence.

TURN EXERCISES INTO TEAM TRAINING

Make it a CTF-style exercise: tune detections, uncover tooling gaps, and rehearse SOC investigation and response.

GO BEYOND THE ENDPOINT

Test identity and cloud techniques too. Can you prevent or detect tools such as Evilginx, MFASweep (use the fork!), ROADtools, GraphSpy, GraphRunner and TeamsFiltration?

Atomic Red Team | FAQs

Can I create my own tests?
Yes - author your own atomic tests.

Can I customize inputs?
Yes - vary arguments to test beyond one fixed signature.

Will it skip incompatible tests?
Platform-specific tests can be selected or filtered. Check applicability before execution.

Can I schedule tests?
Yes - use Invoke-AtomicRunner and a CSV schedule.

Can I run everything at once?
Possible, but not recommended; select a scoped set.

Can I execute remotely?
Yes - remote execution is supported.

Can I contribute?
Yes - follow the contribution guidance. You might even get a T-shirt!

Is there a community?
Yes - there is a Slack community (sorry, not our choice).

SCHEDULING FROM CSV

Invoke-AtomicRunner



References & Further reading

Atomic Red Team test library

github.com/redcanaryco/atomic-red-team

Detection Engineering

detectionengineering.net/

Invoke-AtomicRedTeam documentation

github.com/redcanaryco/invoke-atomicredteam/wiki

Detection Debt 2026 - Spectrum

spectrum.security/detection-debt-2026

MITRE ATT&CK

attack.mitre.org/

Video playlist - detection & testing

youtube.com/playlist?list=PL92eUXSF717VeZ99Z3mO7MW09_mUWX5yr

ATT&CK Navigator

mitre-attack.github.io/attack-navigator/

Related video walkthrough

youtube.com/watch?v=O6w0oFcCAnI

Q&A / Ask the Ninjas

SECURITY NINJA

QUESTIONS?

Jay Kerai • Effie Antoniadi

Atomic installation / Reference commands

SECURITY NINJA

Original example - review code and use only in an authorized, isolated lab:

PowerShell installation example

```
IEX (IWR 'https://raw.githubusercontent.com/redcanaryco/invoke-atomicredteam/master/install-atomicredteam.ps1');
install-atomicredteam -getatomics
```

Lab prerequisites / Details to verify

SECURITY NINJA

- **Isolate the host** - Dedicated VM or AVD host; second tenant if organizational reporting requires strict separation.
- **Device management** - MDE onboarded at minimum; Intune enrollment optional for managing policies.
- **Identity / RBAC** - Dedicated account, scoped Attack Disruption exceptions; device groups and unified RBAC access as relevant.
- **Execution environment** - Some tests need admin rights. Constrained Language Mode may prevent installation and some tests.
- **License & policy checks** - Confirm device entitlements and whether exclusions need approval; document cleanup.

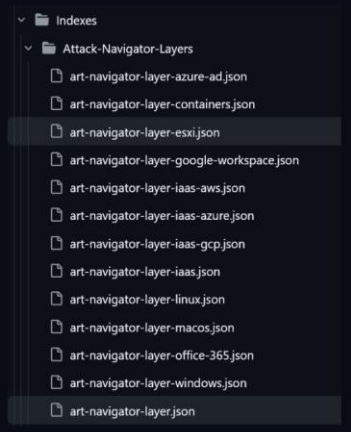
ATT&CK Navigator / How to import a test layer

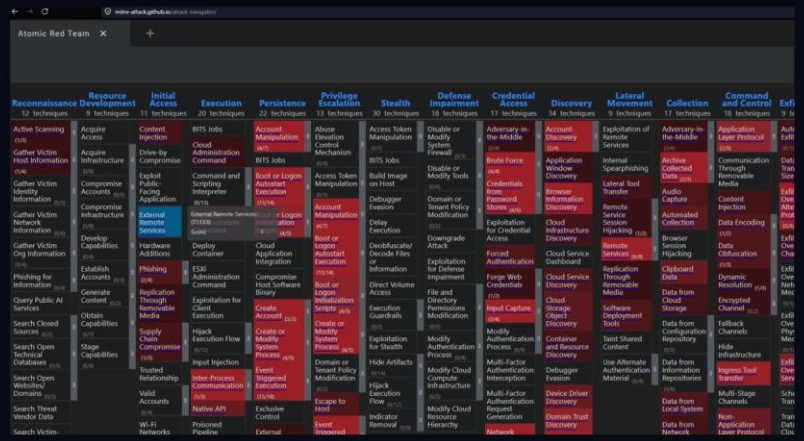
SECURITY NINJA

Mapping Atomics to MITRE

https://github.com/redcanaryco/atomic-red-team/blob/master/atomics/Indexes/Attack-Navigator-Layers/art-navigator-layer.json

https://mitre-attack.github.io/attack-navigator/ - Import from URL -> remember to use RAW link for each json (demo)





SOURCE

Atomic Red Team repository: atomics/Indexes/Attack-Navigator-Layers/

IMPORT

Open ATT&CK Navigator, import from URL, and use the raw JSON URL.

Mapping tests ≠ proof of detection coverage.

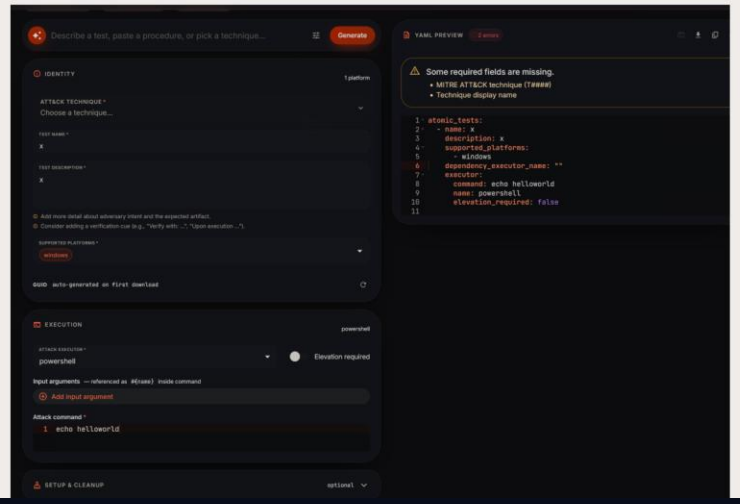
AtomicGen / Create your own atomic test

SECURITY NINJA

30/9/2026

Atomic Create your own test!

https://atomicgen.io/



CUSTOM TESTS

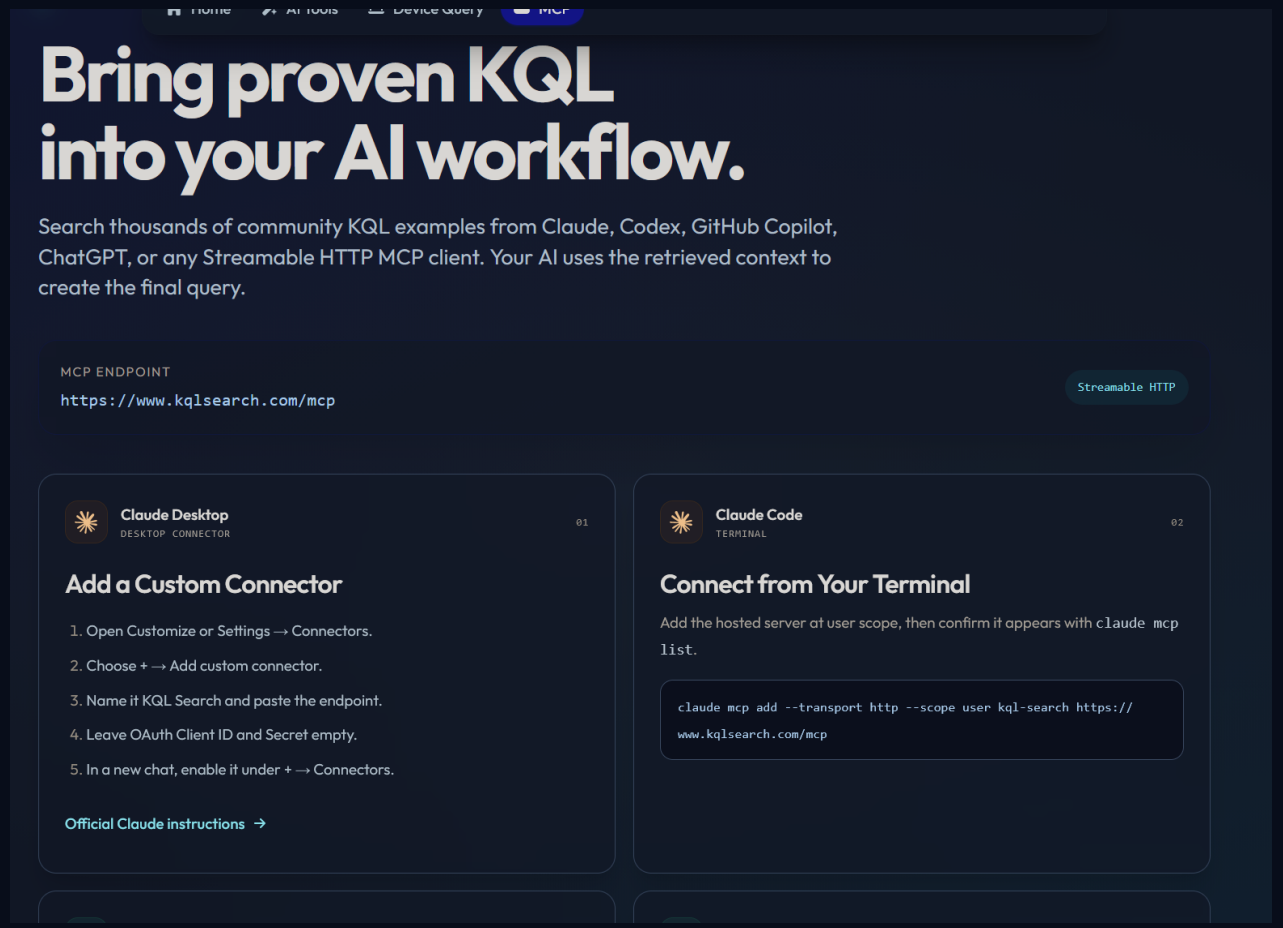
Create or modify a documented ATT&CK-aligned test for a scenario relevant to your environment.

Original resource: atomicgen.io

Review generated YAML and cleanup before execution.

KQLSearch MCP / Optional research tool

SECURITY NINJA



AI-ASSISTED KQL

The original deck suggests KQLSearch MCP to help locate or author queries.

Always validate table names, ActionTypes, columns, and real results in your tenant.

Thank You, Ninjas!



See you next Year!

